

INDEPENDENT BASELINE ASSESSMENT

andrewyng/openworker

OpenWorker Code Intelligence Report

Prioritized source, dependency, workflow, architecture, maintainability, and repository-governance evidence with explicit confidence, applicability, remediation, verification, and claim boundaries.



EXACT TARGET

db93d75bf634 · HEAD

EVIDENCE DISCIPLINE

100% traceable finding coverage

REPORT CONFIDENCE

84/100 · moderate

391 analyzed files

75,301 code LOC

41 findings

clean working tree · fetched history

OVERALL SCORE

75/100

Good with targeted work

SECURITY

63/100

source + dependency + workflow signals

EFFORT RANGE

36–93 days

engineering-only planning range

FINANCIAL IMPACT

Not modeled

A defensible dollar estimate requires organization-specific labor rates, incident history, delivery volume, and change-failure data.

Executive Summary

What the Evidence Says

The repository scores 75/100 (Good with targeted work) with moderate report confidence (84/100).

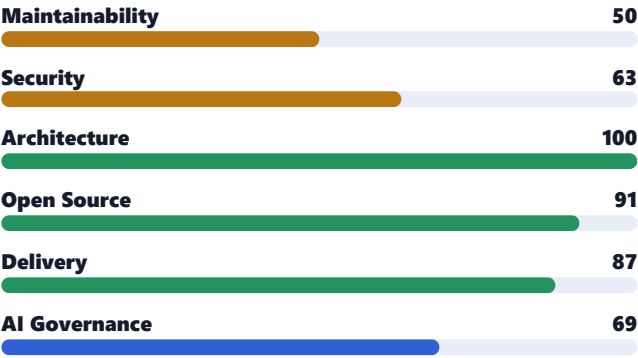
100% of findings contain traceable rule and source or repository evidence; 0 have a confirmed owner and 41 remain unassigned.

Dependency security evidence includes 1 issue(s), with 0 marked fixable by package-manager data.

Repository evidence mapping contains 5 material gap category/categories; this is an alignment signal, not a certification or control-effectiveness conclusion.

The applicable critical/high/medium queue implies roughly 36–93 engineering days before discovery, release coordination, and production validation.

Score Dimensions



EVIDENCE COVERAGE

100%

41/41 findings

CONFIRMED OWNERS

0

41 unassigned

DEPENDENCY VULNS

1

0 critical · 1 high

WORKFLOW GAPS

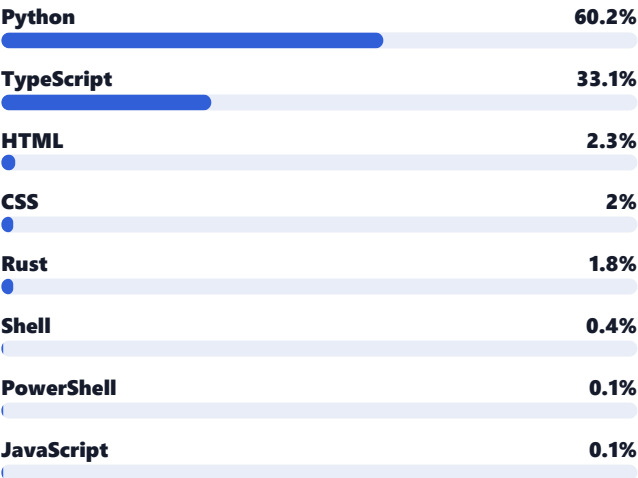
17

mutable action refs + implicit permission policies

Severity / Effort Distribution

	S	M	L	XL
CRITICAL	0	0	0	0
HIGH	0	1	10	0
MEDIUM	3	10	7	0
LOW	8	2	0	0

Codebase Composition



The overall score is a prioritization model. It is not a certification, exploitability determination, valuation opinion, productivity measurement, or substitute for runtime testing and human review.

Methodology, Scope, and Claim Boundaries

Exact Audit Target

Repository: <https://github.com/andrewyng/openworker>
Commit: [db93d75bf634e3a855b29e00d8f5d677438cac1f](#) (July 25, 2026)
Branch: HEAD
Snapshot state: working tree clean; fetched history.
File discovery: Git tracked and non-ignored untracked files.
Generated: July 25, 2026; scanner runtime 1,888 ms.

Coverage and Traceability

SCAN COVERAGE

89.7%

391/436 candidate files

CODE LOC

75,301

82,138 analyzed text lines

EVIDENCE COVERAGE

100%

41 findings with traceable evidence

REPORT CONFIDENCE

84 / 100

moderate confidence

Repository Scope Classification

SCOPE	FILES	HOW FINDINGS ARE INTERPRETED
Production	223	Directly applicable to shipped or runtime code.
Build / delivery control	5	Applies to CI, release, packaging, or infrastructure controls.
Tests and fixtures	155	Contextual evidence; severity is reduced unless production reachability is established.
Examples and documentation	8	Advisory or informational; excluded from direct production-risk claims.
Generated report artifacts	0	Excluded from the report's own finding evidence to prevent self-contamination.

Analysis Procedure

- Enumerate text candidates with size, directory, ignore-file, and generated-artifact limits.
- Classify production, control-plane, test, fixture, example, documentation, and generated scope.
- Extract language-aware units and rule evidence; attach rule IDs, fingerprints, confidence, applicability, remediation, and verification.
- Inspect dependency manifests, lock evidence, package-manager audit output, workflow permissions, and immutable action provenance.
- Score with confidence/applicability weighting and diminishing penalties; do not infer dollar impact or historical trends from a single scan.

Limitations

Static repository analysis cannot prove runtime exploitability, production reachability, or control operation.

Dependency audit coverage depends on available package-manager tooling, network access, and resolvable manifests.

Git history metrics reflect the fetched history window, not necessarily the repository's full lifetime.

Framework mappings are evidence-alignment aids, not certification, attestation, or compliance determinations.

Dependency audit status: 1/2 applicable audit command(s) completed.

Project Profile and Stack Coverage

Detected Project Shape

The scan detected 391 analyzed files, 75,301 lines of code, 4 dependency or build manifest(s), and 8 language signal(s).

JavaScript/TypeScript application or package workspace

Python service, automation, or data/AI codebase

Rust systems, CLI, or backend component

multi-component repository requiring ownership mapping

This page tunes the audit interpretation by stack. A Node/TypeScript repo needs different evidence than a Go service, Ruby app, Rust CLI, JVM service, or .NET system. The remediation plan should preserve proof that fits the language and package ecosystem actually present.

Coverage Signals

ECOSYSTEMS

3

Python, Node.js, Rust

MANIFESTS

4

dependency/build files

LOCK GAPS

1

manifest(s) without lock evidence

LANGUAGES

8

detected code families

Language-Specific Review Focus

LANGUAGE	DEPENDENCY EVIDENCE	AUDIT FOCUS
Python 60.2% 45,314 LOC	Python, Node.js, Rust	requirements/pyproject reproducibility, runtime pinning, data/AI workflow validation, and test evidence.
TypeScript 33.1% 24,942 LOC	Python, Node.js, Rust	package lock integrity, type-safety boundaries, SDK/API drift, test evidence, and dependency reachability.
HTML 2.3% 1,749 LOC	Python, Node.js, Rust	Maintainability, ownership, dependency evidence, and test confidence for this stack.
CSS 2% 1,526 LOC	Python, Node.js, Rust	Maintainability, ownership, dependency evidence, and test confidence for this stack.
Rust 1.8% 1,341 LOC	Python, Node.js, Rust	Cargo.lock policy, crate ownership, unsafe/native boundaries, and release confidence.
Shell 0.4% 276 LOC	Python, Node.js, Rust	Maintainability, ownership, dependency evidence, and test confidence for this stack.

Manifest and Reproducibility Evidence

MANIFEST	ECOSYSTEM	DEPENDENCIES	REPRODUCIBILITY EVIDENCE
pyproject.toml	Python	6	verification gap
surfaces/gui/package.json	Node.js	21	lock/equivalent present
surfaces/gui/src-tauri/Cargo.toml	Rust	10	lock/equivalent present
stt/Cargo.toml	Rust	5	lock/equivalent present

Priority Action Plan

PRIORITY QUEUE
6
highest-confidence applicable findings

EFFORT RANGE
36–93 days
engineering-only estimate

NAMED OWNERS
0
41 findings remain unassigned

VERIFICATION SPECS
100%
remediation plus verification present

Recommended Sequencing

- Contain:** patch exploitable dependencies and tighten delivery controls before broad refactoring.
- Reduce change risk:** split the highest-complexity production units behind tests and stable interfaces.
- Institutionalize:** assign real owners, record acceptance criteria, and retain verification evidence from the next scan.

The effort range is a planning aid derived from finding size and applicability. It excludes discovery, release windows, stakeholder coordination, and production validation.

Highest-Priority Backlog

RISK	EVIDENCE	REQUIRED CHANGE	PROOF OF COMPLETION
HIGH P1 · L effort high confidence	Function complexity hotspot: App surfaces/gui/src/App.tsx:146 clearcode.maintainability.function-complexity-hotspot-app · direct App spans 1455 non-empty lines with 401 decision token(s) and a 74.3/100 modeled complexity score.	Split App around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path.	Run the affected test suite and re-scan surfaces/gui/src/App.tsx:146 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH P2 · L effort high confidence	Function complexity hotspot: Composer surfaces/gui/src/components/Composer.tsx:82 clearcode.maintainability.function-complexity-hotspot-composer · direct Composer spans 434 non-empty lines with 144 decision token(s) and a 60.8/100 modeled complexity score.	Split Composer around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path.	Run the affected test suite and re-scan surfaces/gui/src/components/Composer.tsx:82 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH P3 · L effort high confidence	Function complexity hotspot: Sidebar surfaces/gui/src/components/Sidebar.tsx:173 clearcode.maintainability.function-complexity-hotspot-sidebar · direct Sidebar spans 1083 non-empty lines with 204 decision token(s) and a 69.1/100 modeled complexity score.	Split Sidebar around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path.	Run the affected test suite and re-scan surfaces/gui/src/components/Sidebar.tsx:173 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH P4 · L effort high confidence	Large file hotspot surfaces/gui/src/api.ts:1 clearcode.maintainability.large-file-hotspot · direct 1673 non-empty lines make ownership, testing, and refactoring harder.	Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.	Re-run the scan and review surfaces/gui/src/api.ts:1 for the corrected pattern.
HIGH P5 · L effort high confidence	Large file hotspot surfaces/gui/src/App.tsx:1 clearcode.maintainability.large-file-hotspot · direct 1674 non-empty lines make ownership, testing, and refactoring harder.	Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.	Re-run the scan and review surfaces/gui/src/App.tsx:1 for the corrected pattern.
HIGH P6 · L effort high confidence	Large file hotspot surfaces/gui/src/components/Sidebar.tsx:1 clearcode.maintainability.large-file-hotspot · direct 1335 non-empty lines make ownership, testing, and refactoring harder.	Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.	Re-run the scan and review surfaces/gui/src/components/Sidebar.tsx:1 for the corrected pattern.

Security, Dependencies, and Delivery Controls

Current Risk Baseline

No historical trend series was available in this scan payload, so this page treats the current scan as the baseline for the next remediation cycle.

The baseline is still actionable: 41 unassigned finding(s), 6 repository-governance gap(s), and 5 framework evidence gap category/categories.

The applicable queue implies 36–93 engineering days. The next comparable scan should show finding closure, retained evidence, assigned ownership, and verified dependency/workflow controls.

Risk Signals to Track

SIGNAL	CURRENT VALUE	WHY IT MATTERS
Maintainability debt	50 / 100 high	Prioritize high-risk functions and large files, then convert repetitive patterns into named helpers.
Security debt	63 / 100 high	Resolve critical/high issues first, preserve audit output, and document residual accepted risk.
Framework evidence gaps	41 / 100 high	Attach evidence to each mapped theme, close material gaps, and keep repository policies versioned.
Dependency governance debt	42 dependencies medium	Pin production dependencies, keep lockfiles, record licenses, and enable dependency update automation.
Ownership concentration debt	95% top contributor share medium	Document ownership, rotate reviews, and move implicit operational knowledge into runbooks.

DEPENDENCIES

42

4 manifests

RISKY SPECS

0

unpinned or loose versions

SECURITY FINDINGS

1

0 critical, 1 high

FIXABLE VULNS

0

package-manager remediable

Dependency Audit Evidence

SOURCE	STATUS / SEVERITY	PACKAGE	EVIDENCE
npm-audit	high	xlsx	Prototype Pollution in sheetJS

GitHub Actions Security Evidence

Workflow permissions, trigger privilege, expression interpolation, and action-reference provenance are evaluated independently from application source. Mutable tags and implicit permission defaults are supply-chain control gaps even when no exploit path is confirmed by static analysis.

GitHub Actions Security Evidence

WORKFLOWS
2
analyzed YAML files

EXPLICIT PERMISSIONS
0
2 implicit

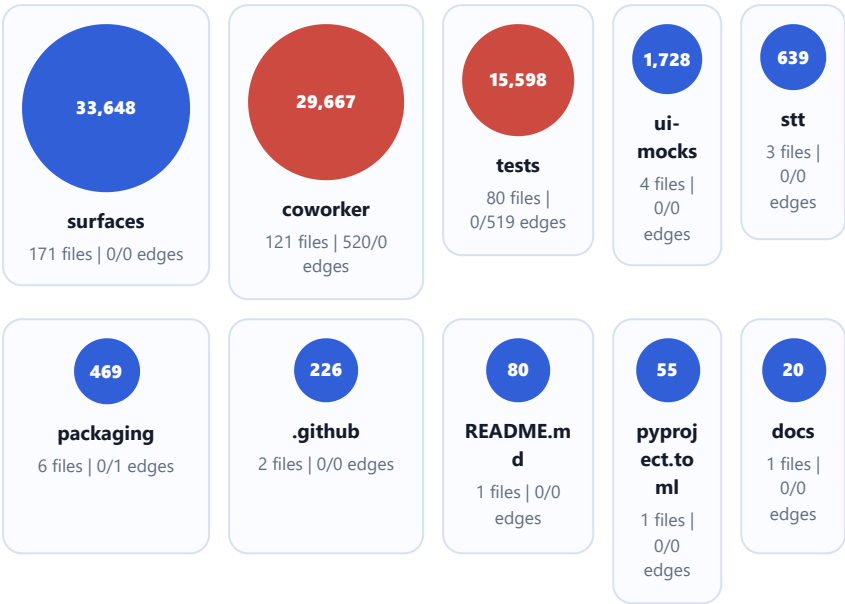
IMMUTABLE ACTIONS
0
15 mutable refs

PRIVILEGED PR
0
pull_request_target workflows

WORKFLOW	PERMISSIONS	ACTION PROVENANCE	PRIVILEGED / INJECTION SIGNALS
.github/workflows/ci.yml	implicit repository default	0 immutable / 6 mutable	none detected
.github/workflows/release.yml	implicit repository default	0 immutable / 9 mutable	none detected

Architecture and Maintainability

Architecture Map



Maintainability Narrative

The repository scores 75/100 (Good with targeted work) with moderate report confidence (84/100).

100% of findings contain traceable rule and source or repository evidence; 0 have a confirmed owner and 41 remain unassigned.

Dependency security evidence includes 1 issue(s), with 0 marked fixable by package-manager data.

Repository evidence mapping contains 5 material gap category/categories; this is an alignment signal, not a certification or control-effectiveness conclusion.

The applicable critical/high/medium queue implies roughly 36–93 engineering days before discovery, release coordination, and production validation.

Coupling and Complexity Signals

	S	M	L	XL
CRITICAL	0	0	0	0
HIGH	0	1	10	0
MEDIUM	3	10	7	0
LOW	8	2	0	0

Technical Debt Register

This register groups evidence by engineering risk domain. Each row connects an observed signal to its likely change-risk implication and a concrete next action; it does not assign financial impact.

DEBT CATEGORY	SIGNAL	SEVERITY	EVIDENCE	ENGINEERING IMPACT	RECOMMENDED ACTION
Maintainability debt	50 / 100	high	30 maintainability finding(s). 60.8 p95 complexity. 32.3% large-unit share.	Higher maintenance cost, slower onboarding, and greater regression risk during feature work.	Prioritize high-risk functions and large files, then convert repetitive patterns into named helpers.
Security debt	63 / 100	high	6 security finding(s). 1 dependency vulnerability signal(s). 0 fixable by package-manager workflow.	Security findings increase exploitability uncertainty, patch urgency, and release-review effort.	Resolve critical/high issues first, preserve audit output, and document residual accepted risk.
Framework evidence gaps	41 / 100	high	0 strong framework signal(s). 1 partial signal(s). 5 evidence gap(s).	Missing repository evidence increases uncertainty during security, quality, and change-control review.	Attach evidence to each mapped theme, close material gaps, and keep repository policies versioned.
Dependency governance debt	42 dependencies	medium	0 risky version spec(s). 1 manifest(s) without lockfile. 0 missing license signal(s).	Unclear dependency provenance weakens technical confidence and increases supply-chain exposure.	Pin production dependencies, keep lockfiles, record licenses, and enable dependency update automation.
Ownership concentration debt	95% top contributor share	medium	4 contributor(s). 59 recent commit(s). 15 git hotspot(s). Ownership inference threshold met.	Knowledge concentration creates key-person risk during handoff and enterprise support.	Document ownership, rotate reviews, and move implicit operational knowledge into runbooks.
Architecture debt	100 / 100	low	11 components. 2 dependency edges. 0 cycle(s).	Coupling increases integration risk, test surface, and cost of changing core workflows.	Break cyclic dependencies, isolate cross-cutting modules, and define ownership boundaries.
Delivery and testing debt	42.1% test ratio	low	4 delivery finding(s). 0 reliability finding(s). 6 safe fix(es) currently available.	Weak verification coverage turns routine fixes into delivery-risking delays.	Add smoke tests for core workflows, then expand regression coverage around risky code paths.

Framework Evidence Mapping

ALIGNMENT INDEX
41/100
weighted repository evidence proxy

STRONG SIGNALS
0
80–100 evidence score

PARTIAL SIGNALS
1
60–79 evidence score

EVIDENCE GAPS
5
below 60 evidence score

These scores map visible repository artifacts to selected framework themes. They do not establish organizational process maturity, operating effectiveness, legal compliance, certification readiness, or audit assurance.

FRAMEWORK THEME	CATEGORY	SIGNAL	REPOSITORY EVIDENCE	PRIORITY ACTION
ISO 9001 ISO 9001:2015 Repository Evidence Signals	Quality process	52/100	Automated tests are present.	Create CI/test gates
ISO 27001 ISO/IEC 27001 Repository Evidence Signals	Security management	10/100	Ignore policy reduces accidental artifact exposure.	Add security policy
ISO 25010 ISO/IEC 25010 Product-Quality Evidence Signals	Product quality	70/100	Architecture score is 100/100.	Reduce red-zone functions
ISO 42001 ISO/IEC 42001 AI-Governance Evidence Signals	AI governance	30/100	100% traceable finding evidence.	Require CI for AI changes
SOC 2 SOC 2 Repository Evidence Signals	Trust controls	28/100	Change verification evidence is present.	Collect security/change-control evidence
Safety High-Assurance Repository Evidence Signals	High assurance	58/100	Automated tests are present.	Add traceable verification gates

Prioritized Findings Ledger

Findings are ordered by severity, then confidence and applicability. Test, fixture, example, and documentation signals are labeled so they cannot silently inherit production-risk claims.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
HIGH L effort	Large file hotspot surfaces/gui/src/api.ts:1 clearcode.maintainability.large-file-hotspot 1673 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/api.ts:1 for the corrected pattern.
HIGH L effort	Large file hotspot surfaces/gui/src/App.tsx:1 clearcode.maintainability.large-file-hotspot 1674 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/App.tsx:1 for the corrected pattern.
HIGH L effort	Large file hotspot surfaces/gui/src/components/Sidebar.tsx:1 clearcode.maintainability.large-file-hotspot 1335 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/components/Sidebar.tsx:1 for the corrected pattern.
HIGH L effort	Large file hotspot coworker/server/app.py:1 clearcode.maintainability.large-file-hotspot 1748 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/server/app.py:1 for the corrected pattern.
HIGH L effort	Large file hotspot coworker/server/manager.py:1 clearcode.maintainability.large-file-hotspot 3477 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/server/manager.py:1 for the corrected pattern.
HIGH L effort	Large file hotspot coworker/connectors/descriptors.py:1 clearcode.maintainability.large-file-hotspot 1385 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/connectors/descriptors.py:1 for the corrected pattern.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 7–12 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
HIGH L effort	Large file hotspot coworker/connectors/integration_tools.py :1 clearcode.maintainability.large-file-hotspot 4516 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/connectors/integration_tools.py:1 for the corrected pattern.
HIGH L effort	Function complexity hotspot: App surfaces/gui/src/App.tsx:146 clearcode.maintainability.function-complexity-hotspot-app App spans 1455 non-empty lines with 401 decision token(s) and a 74.3/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split App around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/App.tsx:146 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH L effort	Function complexity hotspot: Sidebar surfaces/gui/src/components/Sidebar.tsx:173 clearcode.maintainability.function-complexity-hotspot-sidebar Sidebar spans 1083 non-empty lines with 204 decision token(s) and a 69.1/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split Sidebar around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/components/Sidebar.tsx:173 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH L effort	Function complexity hotspot: Composer surfaces/gui/src/components/Composer.tsx:82 clearcode.maintainability.function-complexity-hotspot-composer Composer spans 434 non-empty lines with 144 decision token(s) and a 60.8/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split Composer around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/components/Composer.tsx:82 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
HIGH M effort	Dependency vulnerability: xlsx surfaces/gui/package.json:1 clearcode.security.dependency-vulnerability-xlsx GHSA-4R6H-8V6P-XVW6. Prototype Pollution in sheetJS. No automated fix is available. Reference: https://github.com/advisories/GHSA-4r6h-8v6p-xvw6 .	medium confidence direct applicability production scope	Change: Confirm whether the affected xlsx behavior is reachable; if no fixed release exists, replace or isolate the dependency and document any time-bounded accepted risk with compensating controls. Proof: Re-run the npm-audit audit for surfaces/gui/package.json , execute the affected package tests, and confirm the advisory is removed or explicitly risk-accepted with evidence.
MEDIUM M effort	Contributor concentration risk Repository clearcode.delivery.contributor-concentration-risk 95% of recent commits came from one contributor.	medium confidence review applicability repository scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and confirm the repository-level signal improves.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 13–18 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
MEDIUM M effort	Large file hotspot surfaces/gui/src-tauri/src/lib.rs:1 clearcode.maintainability.large-file-hotspot 711 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src-tauri/src/lib.rs:1 for the corrected pattern.
MEDIUM M effort	Dense lines reduce reviewability surfaces/gui/src/styles.css:185 clearcode.maintainability.dense-lines-reduce-reviewability 31 lines exceed 140 characters, increasing scan and review effort.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/styles.css:185 for the corrected pattern.
MEDIUM L effort	Large declarative file surfaces/gui/src/styles.css:1 clearcode.maintainability.large-declarative-file 1521 non-empty lines concentrate a large declarative surface; review modularity and ownership before splitting it mechanically.	medium confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/styles.css:1 for the corrected pattern.
MEDIUM L effort	Large file hotspot surfaces/gui/src/components/ManageTab s.tsx:1 clearcode.maintainability.large-file-hotspot 851 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/components/ManageTabs.tsx:1 for the corrected pattern.
MEDIUM M effort	Dense lines reduce reviewability surfaces/gui/src/components/SettingsView w.tsx:270 clearcode.maintainability.dense-lines-reduce-reviewability 12 lines exceed 140 characters, increasing scan and review effort.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/components/SettingsView.tsx:270 for the corrected pattern.
MEDIUM L effort	Large file hotspot surfaces/gui/src/components/SettingsView w.tsx:1 clearcode.maintainability.large-file-hotspot 718 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review surfaces/gui/src/components/SettingsView.tsx:1 for the corrected pattern.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 19–24 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
MEDIUM L effort	Large file hotspot coworker/engine.py:1 clearcode.maintainability.large-file-hotspot 956 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/engine.py:1 for the corrected pattern.
MEDIUM L effort	Large file hotspot coworker/connectors/email_tools.py:1 clearcode.maintainability.large-file-hotspot 765 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/connectors/email_tools.py:1 for the corrected pattern.
MEDIUM L effort	Large file hotspot coworker/connectors/tool_defs.py:1 clearcode.maintainability.large-file-hotspot 1172 non-empty lines make ownership, testing, and refactoring harder.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/connectors/tool_defs.py:1 for the corrected pattern.
MEDIUM M effort	Function complexity hotspot: VoicemailSection surfaces/gui/src/components/SettingsView.tsx:143 clearcode.maintainability.function-complexity-hotspot-voicemailsection VoicemailSection spans 193 non-empty lines with 77 decision token(s) and a 68/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split VoicemailSection around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/components/SettingsView.tsx:143 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
MEDIUM M effort	Function complexity hotspot: run surfaces/gui/src-tauri/src/lib.rs:580 clearcode.maintainability.function-complexity-hotspot-run run spans 186 non-empty lines with 23 decision token(s) and a 64.5/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split run around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src-tauri/src/lib.rs:580 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
MEDIUM M effort	Function complexity hotspot: humanizeTool surfaces/gui/src/humanize.ts:29 clearcode.maintainability.function-complexity-hotspot-humanizetool humanizeTool spans 74 non-empty lines with 60 decision token(s) and a 56.9/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split humanizeTool around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/humanize.ts:29 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 25–30 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
MEDIUM M effort	Function complexity hotspot: InboxRoutingCard surfaces/gui/src/components/InboxConfigure.tsx:56 clearcode.maintainability.function-complexity-hotspot-inboxroutingcard InboxRoutingCard spans 100 non-empty lines with 34 decision token(s) and a 56/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split InboxRoutingCard around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/components/InboxConfigure.tsx:56 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
MEDIUM M effort	Function complexity hotspot: ModelsTab surfaces/gui/src/components/ManageTabs.tsx:78 clearcode.maintainability.function-complexity-hotspot-modelstab ModelsTab spans 89 non-empty lines with 24 decision token(s) and a 56/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split ModelsTab around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/components/ManageTabs.tsx:78 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
MEDIUM M effort	Function complexity hotspot: itemsFromMessages surfaces/gui/src/itemsFromMessages.ts:1 clearcode.maintainability.function-complexity-hotspot-itemsfrommessages itemsFromMessages spans 71 non-empty lines with 37 decision token(s) and a 53.8/100 modeled complexity score.	high confidence direct applicability production scope	Change: Split itemsFromMessages around explicit policy, state, or I/O boundaries while preserving its public contract; add focused tests for each extracted path. Proof: Run the affected test suite and re-scan surfaces/gui/src/itemsFromMessages.ts:11 ; verify the function's decision count and modeled complexity both decrease without moving complexity into an untested helper.
MEDIUM S effort	Dependency automation missing .github/dependabot.yml:1 clearcode.open-source.dependency-automation-missing Automated dependency updates reduce CVE drift and support ongoing governance.	high confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
MEDIUM S effort	Webview script evaluation boundary surfaces/gui/src-tauri/src/lib.rs:743 clearcode.security.webview-script-evaluation-boundary This execution or data-handling boundary requires exploitability review before release.	medium confidence direct applicability production scope	Change: Triage exploitability, remove the unsafe pattern, add a regression test, and preserve scan evidence. Proof: Re-run the scan and review surfaces/gui/src-tauri/src/lib.rs:743 for the corrected pattern.
MEDIUM M effort	GitHub Actions use mutable references .github/workflows/ci.yml:12 clearcode.security.github-actions-use-mutable-references 15 external action reference(s) use tags or branches rather than immutable commit SHAs (actions/checkout@v4, actions/setup-python@v5, actions/checkout@v4, actions/setup-node@v4, actions/checkout@v4).	high confidence control applicability control-plane scope	Change: Pin third-party actions to reviewed full-length commit SHAs and retain the release tag in a comment for update tooling. Proof: Re-scan all GitHub workflows and confirm external action references resolve to 40-character commit SHAs.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 31–36 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
MEDIUM S effort	Security policy missing SECURITY.md:1 clearcode.security.security-policy-missing A security policy defines disclosure routing and is expected in diligence-grade repositories.	medium confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
LOW S effort	Git attributes missing .gitattributes:1 clearcode.delivery.git-attributes-missing Repository-wide text normalization avoids cross-platform line ending churn.	medium confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
LOW S effort	Contribution guide missing CONTRIBUTING.md:1 clearcode.delivery.contribution-guide-missing Contribution guidance helps merged teams land consistent changes and avoid process drift.	medium confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
LOW S effort	CODEOWNERS missing CODEOWNERS:1 clearcode.delivery.codeowners-missing Code ownership makes reviews and escalation paths explicit during integration work.	medium confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
LOW S effort	Duplicate implementation block tests/test_automation.py:292 clearcode.maintainability.duplicate-implementation-block 1 duplicate cluster(s), up to 5 repeated blocks across 1 component(s), increase change cost.	high confidence contextual applicability test scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review tests/test_automation.py:292 for the corrected pattern.
LOW M effort	Duplicate implementation block coworker/connectors/browser_automation.py:29 clearcode.maintainability.duplicate-implementation-block 3 duplicate cluster(s), up to 3 repeated blocks across 1 component(s), increase change cost.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/connectors/browser_automation.py:29 for the corrected pattern.

Prioritized Findings Ledger

Continuation of the prioritized evidence ledger. This page contains findings 37–41 of 41 using the same severity, confidence, applicability, and production-scope ordering.

RISK	FINDING AND LOCATION	EVIDENCE QUALITY	REMEDIATION / VERIFICATION
LOW M effort	Duplicate implementation block coworker/providers/anthropic_provider.py:24 clearcode.maintainability.duplicate-implementation-block 1 duplicate cluster(s), up to 3 repeated blocks across 1 component(s), increase change cost.	high confidence direct applicability production scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review coworker/providers/anthropic_provider.py:24 for the corrected pattern.
LOW S effort	Duplicate implementation block tests/test_message_source.py:25 clearcode.maintainability.duplicate-implementation-block 1 duplicate cluster(s), up to 3 repeated blocks across 1 component(s), increase change cost.	high confidence contextual applicability test scope	Change: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks. Proof: Re-run the scan and review tests/test_message_source.py:25 for the corrected pattern.
LOW S effort	EditorConfig missing .editorconfig:1 clearcode.maintainability.editorconfig-missing Shared formatting defaults reduce avoidable diff churn across merged teams.	high confidence control applicability repository scope	Change: Apply the available Create file automation and verify the diff. Proof: Re-run the ClearCode scan and confirm the automated change removed this finding without regressions.
LOW S effort	Workflow token permissions are implicit .github/workflows/ci.yml:1 clearcode.security.workflow-token-permissions-are-implicit 2 workflow(s) rely on repository defaults instead of declaring a read-only token baseline.	high confidence control applicability control-plane scope	Change: Declare top-level read-only permissions and add narrowly scoped job-level write permissions only where required. Proof: Re-scan workflows and confirm every workflow declares an explicit top-level permissions policy.
INFO S effort	Unsafe HTML injection boundary ui-mocks/redesign.html:840 clearcode.security.unsafe-html-injection-boundary 2 instances of this boundary were observed in the file. The pattern occurs in example or prototype. Confirm it cannot reach production inputs or packaged artifacts before treating it as exploitable.	medium confidence contextual applicability example scope	Change: Triage exploitability, remove the unsafe pattern, add a regression test, and preserve scan evidence. Proof: Re-run the scan and review ui-mocks/redesign.html:840 for the corrected pattern.

Code Evidence Snippets

Bounded excerpts preserve the exact source context behind representative priority findings. Rule ID, confidence, fingerprint, remediation, and verification remain attached to each excerpt.

Large file hotspot

L effort

surfaces/gui/src/api.ts:1 | Maintainability | high
clearcode.maintainability.large-file-hotspot | confidence high | fingerprint 007e3a52db12

```
1 import type { SessionInfo, WsEvent } from "../types";  
2
```

1673 non-empty lines make ownership, testing, and refactoring harder.

Remediation: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.

Verification: Re-run the scan and review surfaces/gui/src/api.ts:1 for the corrected pattern.

Large file hotspot

L effort

surfaces/gui/src/App.tsx:1 | Maintainability | high
clearcode.maintainability.large-file-hotspot | confidence high | fingerprint 4578e657c1fb

```
1 import { useCallback, useEffect, useRef, useState, type PointerEvent } from "react";  
2 import {
```

1674 non-empty lines make ownership, testing, and refactoring harder.

Remediation: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.

Verification: Re-run the scan and review surfaces/gui/src/App.tsx:1 for the corrected pattern.

Large file hotspot

L effort

surfaces/gui/src/components/Sidebar.tsx:1 | Maintainability | high
clearcode.maintainability.large-file-hotspot | confidence high | fingerprint d37151b531c9

```
1 import { useEffect, useMemo, useState, type ReactNode } from "react";  
2 import {
```

1335 non-empty lines make ownership, testing, and refactoring harder.

Remediation: Refactor the hotspot into a smaller, named unit and verify behavior with focused tests or checks.

Verification: Re-run the scan and review surfaces/gui/src/components/Sidebar.tsx:1 for the corrected pattern.

Framework Evidence Appendix

These scores map visible repository artifacts to selected framework themes. They do not establish organizational process maturity, operating effectiveness, legal compliance, certification readiness, or audit assurance.

ISO 9001:2015 Repository Evidence Signals

Evidence that the repository can be changed through repeatable, governed engineering process.

Evidence

Automated tests are present.
CI workflow is present.
100% of findings contain traceable rule evidence.

Gaps / Actions

Contribution workflow is missing.
CODEOWNERS is missing.
Create CI/test gates
Document contribution workflow

ISO/IEC 27001 Repository Evidence Signals

Repository-level security governance, vulnerability management, and exposure control signals.

Evidence

Ignore policy reduces accidental artifact exposure.

Gaps / Actions

Security disclosure policy is missing.
Dependency update automation is missing.
Add security policy
Enable dependency automation

ISO/IEC 25010 Product-Quality Evidence Signals

Software quality model coverage across maintainability, reliability, security, compatibility, and operability proxies.

Evidence

Architecture score is 100/100.
Tests support reliability validation.
CI supports repeatable verification.
No architecture cycles detected.

Gaps / Actions

Maintainability score is 50/100.
Security score is 63/100.
Reduce red-zone functions
Strengthen test and CI evidence

Framework Evidence Appendix

These scores map visible repository artifacts to selected framework themes. They do not establish organizational process maturity, operating effectiveness, legal compliance, certification readiness, or audit assurance.

ISO/IEC 42001 AI-Governance Evidence Signals

Controls for AI-assisted repository changes: traceability, human oversight, security, and release discipline.

Evidence

- 100% traceable finding evidence.
- CI can verify AI-assisted changes.

Gaps / Actions

- AI governance score is 69/100.
- Security disclosure path is missing.
- Require CI for AI changes
- Keep human ownership explicit

SOC 2 Repository Evidence Signals

Cloud trust readiness proxy for security, availability, change control, and evidence collection.

Evidence

- Change verification evidence is present.
- Regression testing evidence is present.

Gaps / Actions

- Security policy evidence is missing.
- Approval ownership evidence is missing.
- Collect security/change-control evidence
- Add owner approval gates

High-Assurance Repository Evidence Signals

Advisory proxy for stricter environments such as aviation, automotive, medical, and embedded software.

Evidence

- Automated tests are present.
- CI verification is present.
- No dependency cycles detected.
- Test ratio is 42.1%.

Gaps / Actions

- 11 critical/high finding(s) remain.
- Critical complex unit share is 9.4%, above high-assurance tolerance.
- Add traceable verification gates
- Lower function complexity

Framework Sources and Interpretation Guide

Claim Boundary

These scores map visible repository artifacts to selected framework themes. They do not establish organizational process maturity, operating effectiveness, legal compliance, certification readiness, or audit assurance.

A score is a prioritization aid, not a substitute for threat modeling, runtime testing, architectural review, or audit evidence from organizational processes.

Research Basis

PRIMARY SOURCE	HOW IT INFORMS THIS REPORT	URL
NIST Secure Software Development Framework (SP 800-218)	Secure development practice and verification framing	https://csrc.nist.gov/pubs/sp/800/218/final
OpenSSF Scorecard	Repository security heuristics and explicit false-positive caveats	https://github.com/ossf/scorecard
OWASP Software Assurance Maturity Model	Governance, design, implementation, verification, and operations evidence	https://owasp.org/www-project-samm/
NIST AI Risk Management Framework	Govern, map, measure, and manage framing for AI-enabled systems	https://www.nist.gov/itl/ai-risk-management-framework
OWASP Top 10 for Agentic Applications 2026	Agent execution, tool, identity, memory, and human-oversight threat framing	https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/

Confidence Interpretation

100% of findings include rule, fingerprint, impact, and source or repository evidence.

1/2 applicable package-manager audit(s) completed successfully.

Git history includes 59 fetched commit(s).

High: direct, rule-backed evidence with a specific source or repository control.

Medium: a credible heuristic requiring applicability review.

Low: weak or indirect evidence; do not prioritize without manual confirmation.

Applicability Interpretation

Direct: production-code behavior or maintainability risk.

Control: CI, build, release, workflow, or repository-policy risk.

Review: applicability is unresolved and requires manual inspection.

Contextual / advisory: test, fixture, example, or documentation evidence; excluded from direct production-risk claims.